AI for Good Sandbox Hackathon – Team Sankalp – HISN: the law layer and last mile for agentic government

Team leader: Eswar Panchakarla
Team members: Eswar Panchakarla (engineering), P. Prudhvi Krishna (knowledge base, policy, report)
Contact details: eswarpnbs@gmail.com (Team Sankalp)
Github link: https://github.com/Eswarpnbs/HISN (Apache-2.0; run python selftest.py and python tools/verify_all.py to re-derive every figure)

1. Introduction

The UAE plans to deliver half of its government services through AI agents within two years (Cabinet, 23 April 2026). A national lab tests whether AI models and agents are secure (UAE Cyber Security Council, May 2026), and a planned control tower will log what government agents do and keep them within their authority (Minister of State for AI, 14 October 2026). Two questions remain: is an action lawful, under which clause, and did the citizen actually receive the outcome? Decisions reach people as text messages that pass through AI gatekeepers such as an operator's SMS filter. HISN is designed to complement these systems as the law layer and the last mile: no essential message lost in silence, no rule issued untested. In this use case an operator's AI SMS filter is tightened under pressure after a scam wave, and a genuine, authenticated hospital message is silently dropped while look-alike spoofs probe the same filter. Nobody in the chain can say who may approve a filter change, who protects government and health senders, or who answers for the loss. HISN, a working open-source prototype, governs those decisions: a deterministic policy node blocks only on verbatim, hash-pinned UAE legal clauses; institutional agents (TDRA, Health Authority, Federal AI and Data Authority) propose actions on retrieved evidence; a named human decides; and every step is sealed in a hash-chained audit log.

HISN covers the four agent roles in the brief: a domain solution (the governed SMS firewall), a policy and legal adviser, institutional participants, and multi-agent coordination (the Y.3172 MLFO releases events progressively, so each agent sees only its own events, at its own time). The same engine runs on UAE, India and Singapore by swapping the knowledge base and rule pack, without code changes. We map it to ITU-T Y.3172 (all nine nodes) and the AI Readiness Framework 2.0 (metric IDs checked against ITU's dimensions.json). Each node is grounded in UAE instruments: a knowledge base of 16 hash-pinned official records and 38 verbatim clauses, with India and Singapore packs to test portability. From the mapping we derive seven domain-level policy gaps (G1 to G7) with verified global examples. All data is synthetic or proxy data, and we say so wherever it is used.

2. Description of the use case

The problem is that essential messages (a critical lab result, an appointment change, a traffic-fine receipt) can be lost to an AI filter without anyone knowing, and the rules around that filter are unclear. Existing solutions score messages on keywords, links and sender look-alikes and drop what looks like spam, with no record of why. We found no instrument that gives government or health senders protected status (G2), covers fraud and impersonation in filtering duties (G1), assigns authority to approve or override changes to an operator's AI filter (G5), or allocates scam losses when those duties fail (G6). Language-model assistants that explain the law add a further risk: in our tests an LLM alone made 41 unsupported legal citations on 33 items.

HISN does three things beyond checking AI against existing rules. (1) The right to be reached: essential senders are never silently dropped; a held message goes to a named officer within a clinical time limit, the sender gets an accountable receipt (real SMPP 3.4 server), and every run measures both harms, essential messages lost and scams delivered, as a MIZAN balance. (2) Crash-test the rule: a regulatory wind tunnel tests any draft rule or filter change before issuance against verified law, the hierarchy of norms and nine public-interest invariants, and a gap engine re-runs the scenario with candidate provisions to show which rules carry the load. (3) Declared autonomy, enforced: each component's ITU-T Y.3173 level is declared, observed and enforced, and a change that breaks it is held; named approval plus a second reviewer within a time limit work as maker and checker. Underneath sit standard safeguards: a policy node that blocks only

on a verified binding clause, institutional agents that cite retrieved evidence and only propose (five fixed gates), named human sign-off and a hash-chained audit log.

3. Use case requirement

Each node of the pipeline has requirements, marked critical (C), expected (E) or optional (O).

SRC: C: sender identity comes from the authenticated SMPP bind, never from message text; only synthetic messages with fictional senders are used. E: hospital messages carry a FHIR priority (routine, urgent, asap, stat). O: network stressor data (rain-driven link failures).

C and PP: C: every event and decision sealed in the hash-chained audit log; each agent sees only events addressed to its role and already released; the clinical tier comes only from an authenticated sender's declared priority, never from content; each agent decision is logged with its assessment, retrieved evidence, cited clauses and stated uncertainty (a reviewable rationale, not raw model reasoning). E: a knowledge base of official records, SHA-256 pinned and checkable by anyone.

M: C: the language model only proposes; a decisive action needs a cited source that is binding and within the agent's competence, otherwise a gap is logged. E: pre-registered held-out tests and four baselines (fixed rules, LLM only, LLM with knowledge base, full HISN).

P: C: block only on a verified binding clause; offshore health-data transfers blocked (Federal Law 2/2019 Art. 13); no legitimate essential message silently lost; uncovered events logged as gaps. E: the same rules run on UAE, India and Singapore packs.

D and SINK: C: a held essential message reaches a named officer, with a second reviewer if it is unresolved at the tier limit (5, 15 or 60 minutes; provisional, pending clinician review); the sender gets a receipt with reason and deadline. E: a daily assurance page for the regulator; a citizen verifier in six languages (three reviewed).

MLFO and Sandbox: C: every draft rule and filter change tested before issuance; emergency exceptions must expire; sign-off refused without evidence. E: gap-engine measures of protection, access and MIZAN. O: extrapolation from the UAE to India and Singapore.

4. Mapping with ITU-T Y.3172 Readiness 2.0 Report, and domain-specific policies

	Use case (HISN implementation, data and processing)	**Readiness 2.0 Report**	**Documents (policies, strategies, regulations)**
SRC	SMS over SMPP 3.4; hospital messages as FHIR CommunicationRequest; sender identity from the bound account. Data: synthetic SMS dataset (91 rows, fictional senders, labels by construction, no personal data, CC-BY-4.0); network stressor from the Turkcell 2021 ITU AI/ML in 5G Challenge data, used as a proxy (985,308 link-days, 985 failures, 1,674 radio sites matched to the nearest of 20 weather stations; raw data not redistributed, only an aggregate profile kept; not UAE data).	D1, D4, D13: Area Coverage (d13_m08), Network Quality (d13_m09); open data and open-source management	Federal Law 2/2019 Art. 1 (circulation of health information); TDRA UEC Policy cl. 8.8 (marketing sender label only); India TRAI Government Message definition (IN-TRAI-GOVMSG)
C	Time-gated, role-scoped event bus; hash-chained audit log; SMPP bind and authentication. Agents see only events addressed to their role.	D1, D3, D13: Integrated Workflow (d3_m01); human interaction and supervision	Federal Law 2/2019 Art. 13 (health data stays in the State)
PP	Sender authentication and route checks; clinical tier from declared priority. Knowledge base: 16 official records (UAE, India, Singapore) fetched from the official URLs in kb/manifest.csv and SHA-256 pinned; 38 verbatim clauses extracted with ITU's unmodified ingest pipeline and checked against the source (ligatures and whitespace normalised; 36 exact, 2 layout-reconstructed and declared). No personal data is processed: messages are synthetic and network data is kept only as an aggregate, so no de-identification step is needed.	D1, D2, D3: Coverage and Scale (d3_m07: 3 countries, 16 records, 38 clauses); contextualisation and regional development	Federal Law 2/2019 Art. 16 (consent exceptions)
M	SMS filter scoring; institutional LLM agents with retrieval (qwen2.5:14b); policy and legal adviser; four baselines. Agents only propose; five deterministic gates (evidence, mandate, binding basis, competence, self-consistency); invented citations rejected.	D2, D3, D5, D9: generative AI content ecosystem (LLMs only propose); model and dataset metadata (agent cards with ITU-T Y.3176 fields, dataset datasheet); no	TDRA UEC Policy cl. 1.10, 6.1, 11.1; Cybercrime Law Art. 40 (internet fraud, false impersonation)

		metric ID claimed	
P	Deterministic policy gateway; UAE, India and Singapore rule packs; clinical tiers; wind-tunnel invariants I1 to I9. Blocks only on verified binding clauses; soft law never blocks; uncovered cases logged as gaps; drafts tested before issuance.	D7, D8, D10: Safety Policies (d10_m06), Explainability (d10_m07), Audit (d10_m09), Data Sovereignty (d10_m10), Intent Representations (d7_m03), International Cooperation (d7_m08)	Telecom Law Art. 12, 14(3); Federal Law 2/2019 Art. 13, 16; TDRA UEC cl. 11.1 to 11.2, 13; PDPL Art. 2(2); UAE AI Charter (soft law)
D	Deliver, hold or block decisions; SMPP responses (block = 0x45) and accountable receipts with reason, deadline and audit hash; escalation to the named authority. Essential messages are never silently dropped.	D5, D6, D12: human oversight and inclusion; no metric ID claimed	TDRA UEC Policy cl. 11.1 to 11.2; Telecom Law Art. 14(3) (subscriber service standards)
SINK	Citizen and hospital; named officers and duty supervisor; regulator outputs (daily assurance page, impact cards, gap register, ITU kb_decisions); citizen verifier in six languages (three reviewed, advisory only).	D5, D6, D12, D13: Uptime (d13_m07, 0 silently lost in the daily assurance run); collaboration between AI and human	UAE AI Charter (soft law, human oversight)
MLFO	Coordinator: simulated clock, dispatch, referral routing between authorities (routed once, audited), tier-based second review, emergency state and expiry; one-command reproducibility (selftest.py); CI wind tunnel on pull requests.	D5, D7, D8: Coordination Level (d7_m01, strategy alignment across institutions), Interoperability Standards (d7_m04: SMPP 3.4, HL7 FHIR, Y.3172 export)	Federal Law 2/2019 Art. 13, 24
Sandbox	Governed vs ungoverned twin; gap engine; regulatory wind tunnel; fairness check; filter-change check; synthetic data only.	D10, D11: Policy Sandbox (d10_m01), Policy Evaluation (d10_m02), Policy Extrapolation (d10_m03), Language Repository (d11_m07)	No binding instrument (synthetic sandbox); ITU-T Y.3173 levels (docs/automation_levels.md)

Metric IDs are checked against ITU's simulation/data/framework/dimensions.json (30 Oct 2026). Regional Language Support (d11_m08) is not claimed because the Arabic review is pending.

5. Error scenarios.

Step 1: The governed SMS firewall and agents are deployed in the operator's network and trusted to protect citizens from SMS scams. Sender identity comes from the SMPP account, not from the message.

Step 2 (scam wave): the operator tightens the filter threshold from 0.5 to 0.2 under pressure. A genuine, authenticated hospital message (an appointment change) now scores above it. Ungoverned, it is silently dropped. With HISN it is quarantined and escalated to the Health Authority agent, which proposes release by a named officer with cited evidence; only a named human can release it.

Step 3 (offshore failover): an automatic failover tries to move health data abroad. The policy node blocks it on Federal Law 2/2019 Art. 13 (ungoverned: allowed). Could an emergency justify it? The wind tunnel tests the draft "during a declared emergency, message logs may be stored abroad for 72 hours": as a regulation it is DO NOT ISSUE AS DRAFTED (conflicts with Art. 13); as a Health Authority resolution, Art. 13's own route, it is READY FOR NAMED HUMAN REVIEW. An expiry probe checks that the exception ends (gap G4).

Step 4 (silent retuning): six months later a vendor retunes the threshold to 0.15 without telling the operator or regulator, and a genuine government message (a traffic-fine receipt) is held. The agents ask who may approve or override filter changes. No competence norm exists, so the code turns their answer into a logged gap (G5, discovered by the agents). The audit log records the change as an automation-level violation (ITU-T Y.3173: demand mapping declared human, no named approval). With enforcement switched on (run_demo.py --enforce-levels), both unapproved threshold changes are held for approval and both genuine messages are delivered. Only a signed approval record unlocks a change: it must be bound to that change and value, come from a role competent for filters, be within its validity window and come from someone other than the requester (maker and checker); a typed name, an edited, copied or expired record, or a self-approval is held (run_approval_demo.py; demo keys, not production identity). Headline figures are computed with enforcement off.

Step 5 (where HISN can be challenged): (a) Spoofing: sender authentication plus a verified-sender lane fixes spoofed protected IDs, the clinical hold limit and language dependence (invariants I3, I7, I9) with no regression, and raises the MIZAN score from 76.7 to 94.2; a blunt fraud duty alone lowers it by 0.5. (b) The

model can still be wrong: on the pre-registered held-out set v4 (n=9) it made three errors, all on spoofed messages, one counted as harmful: an unauthenticated message claiming to be a hospital and asking for an ID number was recommended for release. In the prototype a release recommendation only creates a record for a named human, but the gate checks that a cited source is binding, not that it applies to the action. We report this as a limitation. (c) Language fairness: the same message can be scored unequally across languages; a filter-change check blocks biased threshold changes. (d) Cross-border: a genuine foreign essential sender arrives like a spoof (G7), measured from India to the UAE.

Evidence. Twin run: legitimate essential messages silently lost 10 to 0; offshore transfers not blocked 2 to 0. On 33 gold items (qwen2.5:14b) full HISN scored 26/33 (62-89%) with 1 harmful decision and 0 unsupported citations; the LLM alone scored 16/33 with 10 harmful and 41 unsupported; fixed rules 23/33 with 10 harmful; RAG without gates 23/33 with 9 harmful. Accuracy intervals overlap, so we claim a difference in harm and citation support, not in accuracy. Pre-registered held-out sets (gold committed before any scored run, checked by tools/verify_all.py): v2 4/4, v3 1/2, v4 6/9, paraphrase 6/8, 17/23 in total (about 54-87%); these sets are small. Agent decisions were identical across repeated runs (44/44).

6. Policy gaps and standards gaps derived from the mapping exercise

Seven domain-level gaps came out of the mapping and the scenarios. G1 to G4 are verified within the instruments searched; G5 and G7 were discovered by the system; G6 is led by a comparator. These are domain-level findings, not claims that a country breaks its law, and we make no national recommendation.

Gap	Finding and evidence	Verified global example and what transfers	Policy or standards implication
G1	Telecom filtering duties cover marketing spam, not fraud or impersonation. The word "fraud" has zero hits in the TDRA UEC Policy (searched 26 Oct 2026); cl. 1.10, 6.1, 11.1; Cybercrime Law Art. 40.	Australia: Scams Prevention Framework Act 2025 and Industry Code C661:2022 put scam-prevention duties on telecoms. The design transfers; the legal setting differs.	Extend filtering duties to fraud and impersonation (legislative scope).
G2	Government and health senders lack protected status. Business sender IDs are registered through operators and marketing senders carry the AD- label (cl. 8.8), but we found no instrument that protects government or health messages from AI filtering or requires that they are never silently dropped; cl. 13; PDPL Art. 2(2).	India: TRAI regulations define Government Messages, sent through DLT with a "-G" header and not blockable through preferences. Australia: the SMS Sender ID Register keeps registered names (including government) and labels unregistered senders.	A protected sender register with authentication; in our gap engine it raised MIZAN from 76.7 to 94.2.
G3	AI scanning of health SMS for fraud has no explicit legal basis. Federal Law 2/2019 Art. 16 lists five exceptions; telecom fraud filtering is not one; PDPL Art. 2(2).	EU Regulation 2021/1232: a purpose-limited, temporary legal basis for voluntary scanning. Its subject (child sexual abuse material) differs, so only the legal-basis design transfers.	A narrow, purpose-limited legal basis; proposed for ITU standards work.
G4	No emergency path for systematic, AI-triggered failover of health data. Art. 13 violations carry AED 500,000-700,000 (Art. 24); the Executive Regulation lets a provider open one patient's file without consent, nothing more.	EU: GDPR Art. 49(1)(f) and EDPB Guidelines 2/2018: vital interests cover specific, occasional cases, not systematic transfers. The same gap exists there.	A pre-approved, time-limited emergency route, tested in the wind tunnel.
G5	No instrument assigns authority to approve, override or require protection in operators' AI filters. Discovered by the agents; general powers over subscriber service standards (Telecom Law Art. 14(3)) are not applied to AI filter changes.	Australia: Code C661 has blocked scam SMS reported to the ACMA (partial). No pre-deployment approval authority found in Australia or the EU.	An authority and an approval record for filter changes; proposed for ITU standards work (Y.3173: demand mapping = human).
G6	No allocation of scam losses to telecom operators when anti-scam duties fail; bank-side compensation exists (CBUAE Consumer Protection Regulation, Circular 8/2020, Art. 6).	Singapore Shared Responsibility Framework: the telco bears SMS-scam losses when it breached its filtering duties and the bank complied.	Define telecom-side responsibility. A second search pass found bank-side refunds only (Central Bank, reported July 2026).
G7	Essential-sender recognition does not cross borders. India identifies government messages domestically (DLT, "-G" suffix); the UAE recognises only marketing labels; a	Singapore Sender ID Registry (partial): overseas senders only through a Singapore entity; protection applies to Singapore numbers only; no mutual	An open question for international coordination; needs expert review.

	genuine foreign sender arrives like a spoof (measured).	recognition found.	

Standards gaps. (1) Policy as code: no standard format exists for machine-readable rules that say who may block, on what basis and with which evidence. Every HISN rule is a YAML record bound to a hash-pinned clause, for example: id HEALTH_LOCALISATION_01; applies_to message_log_transfer; condition health data, destination outside AE; action BLOCK_PROHIBITED; basis FEDERAL_LAW; citation UAE-FL-2-2019 Art. 13 with verbatim quote, penalty and exception. We offer the schema to ITU. (2) Authority record for agent actions: ITU-T Y.3173 lets a component declare its demand mapping as human, but no standard defines the record that proves a human approved a change (G5). HISN proposes one record joining the declared Y.3173 level, the named approval and the cited binding clause, as input to ITU's new work on trust and identity for agentic AI. (3) No standard for cross-border recognition of essential senders (G7). (4) Readiness Framework gap: ITU's dimensions.json has 13 dimensions and 111 metrics, none of which measures whether an agent's consequential action had verified authority or approval; agents appear once, as a user-interface metric (d11_m03 Edge AI Agents). We propose an agent-authority metric.

Limits we state. Data are synthetic, or a proxy (the Turkcell 2021 ITU challenge link data, used only for stressor statistics; no raw data redistributed). Test sets are small and the intervals wide, so the results show direction, not real-world magnitude. Approval signatures use demo keys, not a production identity service, the firewall is a stand-in for a production SMSC, and 3 of 6 verifier languages are reviewed by a native reader. Two of 38 clauses were reconstructed from page layout and are marked as such. Comparator texts are checked against official pages; the EU regulation number (2026/1881) is confirmed on EUR-Lex.

Next steps. move signed approvals from demo keys to the authority's own identity service and add a check that a cited source applies to the action (the v4 error); native review of the other three languages; expert review of G3, G4 and G7 before any proposal to ITU; run HISN in the ITU Sandbox.

Reproduce. Repository https://github.com/Eswarpnbs/HISN (Apache-2.0): bash setup.sh, then python tools/verify_all.py checks source hashes, verbatim clauses, audit chains and the order of gold files in git history; python selftest.py re-derives every number above.